OutSystems Security Specialist 模擬試験問題集

Nov 5, 2026 · @na

この問題集について

指定された OutSystems 公式ドキュメント22ページの記述だけをもとに、4択・単一選択の問題を50問作成しています。各問の直後に正解・解説・出典ページを付け、最後に解答一覧表を置いています。

- 本番試験の出題範囲・形式を再現したものではありません。公式の試験ガイドで範囲を必ず確認してください。
- 解説は出典ページの記述に基づきます。ページの内容は更新されることがあるため、気になる箇所は出典リンクで最新の記述を確認してください。
- 解答を隠して解きたい場合は、各章を印刷するか、正解行を折りたたんで使ってください。

第1章 認証・ブルートフォース対策・エンドユーザー認証（Q1–Q9）

Q1. 認証の脆弱性対策として、OutSystemsが「機密情報やセッションIDがクリアテキストで送信される」ケースに推奨している対応はどれか。

- A. セッションIDをローカルストレージに保存する
- B. HTTPSを使用し、HSTSを有効にする
- C. セッションタイムアウトを短くする
- D. ログイン画面にCAPTCHAを追加する

正解: B — 機密情報・セッションIDのどちらのケースも、HTTPSを常に使い、HSTSを有効にすることが推奨されています。（出典）

Q2. 特定のIPアドレスから特定ユーザーのパスワードを繰り返し試す「ユーザーレベル攻撃」を検知したとき、OutSystemsのブルートフォース保護はどう動作するか。

- A. そのユーザーアカウントを全IPアドレスから恒久的にロックする
- B. 攻撃元IPアドレスからの全ユーザーのログインを恒久的に遮断する
- C. 攻撃元IPアドレスからの、そのユーザーのログインのみをブロックする
- D. 管理者にメール通知するだけでログインは制限しない

正解: C — ユーザーレベル攻撃では、そのユーザーは攻撃元IPからのみブロックされ、正規ユーザーは攻撃に使われていないIPからはログインできます。（出典）

Q3. 「IPレベル攻撃」に対してIPアドレスごとブロックする主な理由として、ドキュメントで挙げられているものはどれか。

- A. 攻撃者がユーザー一覧を総当たりしてアプリを大量リクエストで溢れさせ、DoSにつながるのを防ぐため
- B. セッションIDの盗聴を防ぐため
- C. SQLインジェクションを防ぐため
- D. ライセンスのエンドユーザー数を抑えるため

正解: A — IPを遮断することで、攻撃者が全ユーザーを試してリクエストを溢れさせること（DoS攻撃につながりうる）を防ぎます。（出典）

Q4. アプリケーションユーザー向けブルートフォース保護のサイトプロパティ `MaxUsernameAttemptsFirstBackoff` の既定値はどれか。

- A. 3回
- B. 5回
- C. 6回
- D. 20回

正解: A — ユーザー単位の第1バックオフは3回、第2バックオフ（`MaxUsernameAttemptsSecondBackoff`）は6回が既定です。20回はIP単位の第1バックオフの既定値です。（出典）

Q5. ブルートフォース保護の既定値の組み合わせとして正しいものはどれか。

- A. `MaxIPAttemptsSecondBackoff` = 30回、`InvalidLoginCheckWindowInMinutes` = 30分
- B. `MaxIPAttemptsSecondBackoff` = 50回、`IPAttemptsSecondBackoffDelayInSeconds` = 3600秒
- C. `UsernameAttemptsFirstBackoffDelayInSeconds` = 300秒、`IPAttemptsFirstBackoffDelayInSeconds` = 30秒
- D. `UsernameAttemptsSecondBackoffDelayInSeconds` = 3600秒、`InvalidLoginCheckWindowInMinutes` = 15分

正解: B — 既定値はIP第2バックオフ50回・その遮断3600秒、ユーザー第1遮断30秒・第2遮断1800秒、IP第1遮断300秒、失敗を数える時間枠60分です。C はユーザーとIPの値が逆です。（出典）

Q6. アプリケーションユーザー（エンドユーザー）向けのブルートフォース保護の設定を変更する場所はどれか。

- A. LifeTimeの「Infrastructure」タブ
- B. Service Studioのモジュールプロパティ

- C. Service Centerの「Factory」>「Modules」で Users モジュールを開き、「Site Properties」タブ
- D. Forgeの Factory Configuration アプリ

正解: C — エンドユーザー向けは Users モジュールのサイトプロパティで設定します。この設定は LifeTime / Service Center（ITユーザー）の保護には影響しません。（出典）

Q7. ITユーザー（Service Center・LifeTimeにログインするユーザー）向けのブルートフォース保護の既定動作を変更する方法として正しいものはどれか。

- A. Users モジュールのサイトプロパティを変更する
- B. Factory Configuration アプリをインストールし、すべてのアプリケーション環境と LifeTime 環境で同じ設定を適用する
- C. LifeTime環境だけで Factory Configuration を使って設定する
- D. ITユーザー向けの保護は既定で無効なので、有効化から行う

正解: B — ITユーザー向け保護は既定で有効です。変更は Forge の Factory Configuration で行い、全環境で設定をそろえる必要があります。（出典）

Q8. パスワードを忘れて何度も失敗し、ブロックされてしまった正規のエンドユーザー1名を解除する手順として正しいものはどれか。

- A. Users アプリでそのユーザーの詳細ページを開き、「Blocked Login Attempts」セクションの「Unblock」をクリックする
- B. Service Studioでアプリを再パブリッシュする
- C. LifeTimeの「Environments」タブでユーザーを削除して再作成する
- D. 既定の遮断時間が過ぎるまで待つ以外に方法はない

正解: A — エンドユーザーは Users アプリのユーザー詳細ページ下部から解除します。IP単位で解除する場合は「Blocked Addresses」リンクを使います。（出典）

Q9. エンドユーザー認証の既定方式「Internal」での認証情報の扱いとして正しいものはどれか。

- A. 資格情報を可逆暗号化してOutSystemsデータベースに保存する
- B. 資格情報は保存せず、資格情報から計算した暗号学的ハッシュの結果のみを保存して照合する
- C. 資格情報は外部IdPにのみ保存される
- D. 資格情報を平文で保存し、DB全体を暗号化して保護する

正解: B — Internal方式では資格情報そのものは保存せず、ハッシュ値だけを保存し、ログイン時に再計算して比較します。なお、エンドユーザーに異なる2つの認証方式を同時に設定することはできず、2つ目が必要なら独自のユーザープロバイダを実装します。（出典）

第2章 ロールとアクセス制御（Q10–Q17）

Q10. `Check<ロール名>Role` を **非アクティブ** なユーザーに対して実行した場合の結果として正しいものはどれか。

- A. そのユーザーにロールが付与されていれば True を返す
- B. ロールが付与されていても常に False を返す
- C. 例外 `Not <ロール名>` が発生する
- D. ユーザーを自動的にアクティブ化してから判定する

正解: B — `Check<ロール名>Role` はアクティブユーザーにのみ適用され、非アクティブユーザーでは付与済みでも常に False です。一方、`Grant<ロール名>Role` はアクティブ・非アクティブの両方に使えます。（出典）

Q11. システムロール **Anonymous** と **Registered** について正しい記述はどれか。

- A. `Grant<ロール名>Role` と `Revoke<ロール名>Role` は使用できない
- B. `Check<ロール名>Role` は使用できない
- C. Users アプリから任意のユーザーに付与・取り消しする必要がある
- D. カスタムロールと同じく Grant / Revoke アクションが自動生成される

正解: A — Grant / Revoke アクションはシステムロールの Anonymous と Registered では利用できません。（出典）

Q12. `Check<ロール名>Role` の任意入力パラメータ **UserId** を省略し、かつ誰も認証されていない状態で呼び出した場合、何が UserId として使われるか。

- A. 最後にログインしたユーザーのID
- B. 管理者ユーザーのID
- C. `NullIdentifier()`
- D. 呼び出しはコンパイルエラーになる

正解: C — UserId 省略時は認証中のユーザーを確認し、認証ユーザーがいなければ `NullIdentifier()` が使われます。（出典）

Q13. 特定のロールが必要な画面に、そのロールを持たないユーザーがアクセスしたときに発生する例外はどれか。

- A. `Security Exception`
- B. `Not <ロール名>`
- C. `Database Exception`
- D. `User Exception`

正解: B — ロールごとに `Not <ロール名>` 例外が作られ、必要なロールを持たないユーザーが画面などにアクセスしたときに発生します。（出典）

Q14. 画面のアクセス制御について、ドキュメントの注記として正しいものはどれか。

- A. 画面の Roles プロパティは表示上の設定にすぎず、アクセス制御には使えない
- B. 匿名（Anonymous）の画面はパブリックエンドポイントを生成するため、CSRF攻撃につながるセキュリティリスクになりうる
- C. Anonymous を付けた画面は自動的にCSRF対策が強化される
- D. 画面にロールを設定すると、その画面のサーバーアクションも自動的に公開APIになる

正解: B — 画面へのアクセスは Roles プロパティで制限します。匿名画面はパブリックエンドポイントを生成するため、CSRFにつながる可能性があると注記されています。（出典）

Q15. 権限のないユーザーに特定の削除処理をさせたくない。OutSystemsの推奨に照らして最も適切な対策はどれか。

- A. 削除ボタンを無効化（Disabled）する
- B. 削除ボタンを If ウィジェットで非表示にするだけにする
- C. 削除処理のコードを実行する前に、現在のセッションにその権限があるかを確認する
- D. ボタンのラベルを権限者にしか分からない文言にする

正解: C — UIのアクションを無効化・非表示にしても、POSTリクエストの強制や偽造による実行は防げません。コード実行前に実行時の権限を確認することが推奨されています。（出典）

Q16. 権限チェックを画面の **Preparation** でのみ行うことが推奨されない理由として、ドキュメントで挙げられているものはどれか。

- A. Preparation ではロール関数を呼び出せないため
- B. 2つ目のタブを開いた場合やブラウザの戻るボタンで、古いページの値が使われることがあるため
- C. Preparation はクライアント側でしか実行されないため
- D. Preparation で権限チェックをするとパフォーマンスが大幅に低下するため

正解: B — 古いページや画面の値が使われうるため、Preparationで計算した情報に頼らず、アクション実行時にサーバーが適用可否を検証する必要があります。なお、画面に情報を表示する際の表示可否の確認は Preparation で行うことが推奨されています。（出典）

Q17. アクセス制御の脆弱性対策として、ドキュメントで推奨されているものはどれか。

- A. 連番のIDを使い、URLから直接レコードを参照できるようにする
- B. 推測できないIDを使用する
- C. すべてのロールに同じページを表示し、ボタンの表示だけを切り替える
- D. 権限チェックはクライアントアクションのみで行う

正解: B — 「IDを設定する」ユースケースでは推測できないIDの使用が推奨されています。また、ロールに応じて利用可能なアクションを含むようページを調整することも推奨事項です。（出典）

第3章 インジェクション・XSS・CSP（Q18–Q28）

Q18. エンドユーザーが入力した文字列を、HTMLリテラルの中で安全に使えるよう特殊文字を置き換えるビルトイン関数はどれか。

- A. `EncodeSql()`
- B. `EncodeHtml()`
- C. `EncodeUrl()`
- D. `GetUserId()`

正解: B — HTMLリテラル内で使う文字列には `EncodeHtml()`、JavaScriptリテラル内なら `EncodeJavascript()` を使います。（出典）

Q19. エンドユーザーが入力した **HTMLコンテンツ** そのものに悪意のある内容が含まれないようにしたい。推奨されるものはどれか。

- A. Sanitization API の `SanitizeHtml()` を使う
- B. `EncodeSql()` を使う
- C. Expression の Escape Content を No にする
- D. CSPで `unsafe-inline` を許可する

正解: A — HTMLとして入力された値には Sanitization API の `SanitizeHtml()` を使うことが推奨されています。（出典）

Q20. SQL要素のクエリパラメータの **Expand Inline** プロパティについて正しい記述はどれか。

- A. 既定で有効になっており、SQLインジェクション対策のため無効化が推奨される
- B. 既定で無効になっており、無効のときはSQLパラメータとして扱われるためSQLインジェクションに対する既定の保護になる
- C. 有効にしても、プラットフォームが自動的に値をエスケープするため安全である
- D. Aggregate でのみ使用できるプロパティである

正解: B — Expand Inline は既定で無効で、その状態ではSQLパラメータ（準備された文）が使われます。有効にすると値がSQLパラメータとして扱われず、SQLインジェクション警告が出ます。（出典）

Q21. Expand Inline を有効にした文字列パラメータに `EncodeSql()` を使う方法として、ドキュメントで推奨されているものはどれか。

- A. `EncodeSql("WHERE surname = " + var1 + " OR name = " + var2)` のように、SQLフラグメント全体をエンコードする
- B. `"'" + EncodeSql(変数) + "'"` のように、文字列リテラル部分だけをエンコードして一重引用符で囲む
- C. `Replace()` で一重引用符を手動で置き換える

- D. `EncodeHtml()` で代用する

正解: B — EncodeSql は文字列リテラルのみに使い、常に一重引用符で囲みます。フラグメント全体のエンコードは不適切で警告が出ます。Replace による手動エンコードもエラーを招きやすいため避けます。（出典）

Q22. 動的な `WHERE column IN (@values)` 句を安全に作成する方法として、ドキュメントで推奨されているものはどれか。

- A. `EncodeSql(name1 + "," + name2 + "," + name3)` で値全体をラップする
- B. Sanitization API の `BuildSafe_InClauseIntegerList` / `BuildSafe_InClauseTextList` を使う
- C. 値をカンマ区切りでそのまま連結する
- D. `EncodeUrl()` で値をエンコードする

正解: B — 値全体を EncodeSql でラップする方法ではSQLインジェクションから保護されないと明記されています。IN句には BuildSafe_InClause 系の関数を使います。（出典）

Q23. Expand Inline の使用を避けるべき理由として、セキュリティ以外にドキュメントで挙げられている影響はどれか。

- A. モジュールのパブリッシュができなくなる
- B. インラインパラメータが頻繁に変わると、データベースが実行計画を最適化できずパフォーマンスに影響する
- C. クエリ結果が自動的にキャッシュされなくなる
- D. ライセンスの消費量が増える

正解: B — インラインパラメータが変わるたびに異なるクエリが生成され、実行計画を最適化できないため、性能に大きな影響が出るとされています。（出典）

Q24. Service Studio で「HTMLインジェクションに関する警告」が出た。推奨される対応に**含まれる**ものはどれか。

- A. Expression の Escape Content プロパティを有効化する
- B. 警告を非表示にして放置する
- C. Expand Inline を有効にする
- D. 画面の Roles に Anonymous を追加する

正解: A — 推奨事項は、Escape Content の有効化、EncodeHtml / EncodeJavascript / EncodeUrl の使用、Sanitization の SanitizeHtml の使用です。（出典）

Q25. フォームデータやURLパラメータを使ってリダイレクト先URLを動的に組み立てる場合に、パラメータ値に使うことが推奨されるビルトイン関数はどれか。

- A. `EncodeUrl()`
- B. `EncodeSql()`

- C. `EncodeJavascript()`
- D. `SanitizeHtml()`

正解: A — `EncodeUrl()` は英数字以外の文字を置き換え、URLパラメータ値で安全に使えるようにします。（出典）

Q26. LifeTime でコンテンツセキュリティポリシー（CSP）を環境レベルとアプリレベルの両方に設定した場合の動作として正しいものはどれか。

- A. 環境レベルの設定がアプリレベルの設定を上書きする
- B. アプリレベルの設定が環境レベルの同じポリシーを上書きする
- C. 両方のディレクティブが重複してヘッダーに出力される
- D. 後から保存した方が常に優先される

正解: B — 設計上、アプリレベルのCSPが環境レベルの同じポリシーを上書きします。設定後はアプリの再パブリッシュが必要です。（出典）

Q27. CSPを設定した後、CSPによってブロックされたリソースを確認する方法として正しいものはどれか。

- A. LifeTime の Analytics タブで確認する
- B. Service Center の Monitoring > Errors で、Source フィルタを「CSPReport」にする
- C. Users アプリの Blocked Addresses で確認する
- D. ブラウザのキャッシュを削除すると一覧が表示される

正解: B — ブロックされたリソースは Service Center の Monitoring の Errors で、Source を CSPReport にして確認します。（出典）

Q28. リアクティブWebアプリから `unsafe-eval` / `unsafe-inline` ディレクティブを除去する方法として正しいものはどれか。

- A. LifeTime の CSP 設定で `unsafe-eval` の行を削除するだけでよい
- B. Factory Configuration の Runtime セクションで「Enforce Unsafe Eval Reactive」「Enforce Unsafe Inline Reactive」のチェックを外し、Deployment Controller サービスの再起動とアプリの再パブリッシュを行う
- C. IIS の HTTP ヘッダー設定で直接CSPを書き換える
- D. 既定で無効なので何もする必要はない

正解: B — 両チェックボックスは既定でオンです（Platform Server 11.28.0 以降が対象）。変更後は Deployment Controller サービスの再起動と全アプリの再パブリッシュが必要です。なお、セルフマネージド環境では IIS などで直接CSPを設定すると重複するため、LifeTime でのみ設定します。（出典）

第4章 CSRF・リダイレクト・暗号化/SSL/TLS（Q29–Q36）

Q29. 従来のWebアプリケーションにおける、OutSystemsのビルトインCSRF保護の仕組みとして正しいものはどれか。

- A. すべてのリクエストに X-CSRFToken ヘッダーを付与する
- B. CAPTCHAをすべてのフォームに自動挿入する
- C. ビューステートが osVisitor Cookie で署名され、リクエスト時にその署名が osVisitor と照合される
- D. Referer ヘッダーのドメインのみで判定する

正解: C — 従来のWebではビューステートを osVisitor Cookie で署名し、送信やAjaxのリクエスト時に照合します。（出典）

Q30. リアクティブWebアプリケーションにおける、ビルトインCSRF保護の仕組みとして正しいものはどれか。

- A. ビューステートを osVisitor Cookie で署名する
- B. すべてのリクエストをPOSTに変換する
- C. セッションIDをURLパラメータに付与する
- D. nr2<ユーザー> Cookie から X-CSRFToken を取り出し、後続リクエストのヘッダーとして送信する

正解: D — リアクティブWebでは nr2<ユーザー> Cookie から X-CSRFToken を抽出し、ヘッダーで送信します。A は従来のWebの仕組みです。（出典）

Q31. OutSystemsで開発するAPIとCSRFについて、正しい記述はどれか。

- A. APIには既定でCSRF防止トークンが含まれるため、追加対策は不要
- B. GETリクエストでは Preparation でアクションを実行してよい
- C. APIには既定でCSRF防止トークンが含まれないため、開発者が対策する必要があり、REST API設計ではCookieを使わない
- D. REST APIはCookieによる認証を使うことが推奨される

正解: C — APIは開発者の責任範囲で、CSRF防止トークンは既定で含まれません。GETでは Preparationでアクションを実行せず、REST API設計ではCookieを使わないことが推奨されています。（出典）

Q32. POSTリクエストを受け付けるAPIをCSRFから保護するための推奨アクションはどれか。

- A. POSTをGETに変更する
- B. レスポンスにHSTSヘッダーを付ける
- C. ボタンを非表示にする

- D. リクエストに一意のトークンがあることを確認し、セッションの期待値と照合して検証する

正解: D — POSTでは一意のトークンの存在を確認し、セッションの期待値と照合することが推奨されています。（出典）

Q33. 入力パラメータに含まれる動的URLへリダイレクトする機能について、未検証リダイレクト対策として推奨されているものはどれか。

- A. リダイレクト前に確認ダイアログを表示すれば十分
- B. URLを Base64 でエンコードしてから渡す
- C. 動的URLの外部サイトを使わない。どうしても必要な場合は入力URLを許可リストと照合する
- D. HTTPSのURLであれば検証は不要

正解: C — 動的URLの外部サイトは使わないことが基本で、必要なら許可リストで照合します。（出典）

Q34. 保存データの暗号化について、ドキュメントの記述として正しいものはどれか。

- A. Cloud・オンプレミスのどちらでも、保存データの暗号化は顧客が手動で行う必要がある
- B. オンプレミス環境では保存データが自動的に暗号化される
- C. Cloud では暗号化されないため、CryptoAPI の利用が必須である
- D. OutSystems Cloud ではユーザーが保存したすべてのデータが自動的に暗号化され、オンプレミスではすべてのチャネルと機密データの暗号化が推奨される

正解: D — Cloud では保存データが自動暗号化されます。オンプレミスでは、すべてのチャネルと機密データを暗号化することが推奨されています。（出典）

Q35. ビルトインのエンドユーザーおよびITユーザーのパスワードのハッシュ化に OutSystems が使用しているアルゴリズムはどれか。

- A. ソルト付き SHA512
- B. MD5
- C. AES-256
- D. SHA1（ソルトなし）

正解: A — パスワードはソルト付き SHA512 でハッシュ化されます。AES-128 / AES-256 はデータ暗号化の推奨方式で、Forge の CryptoAPI コンポーネントと鍵管理システムの使用が推奨されています。（出典）

Q36. Cookie の送信方法を保護するために推奨されている対応はどれか。

- A. Cookie の有効期限を無期限にする
- B. Cookie の値を EncodeHtml でエンコードする

- C. アプリケーション/サーバーでセキュアなCookieを有効にし、HSTS ヘッダーを有効にする
- D. Cookie をローカルストレージに移す

正解: C — セキュアなCookieの有効化と、クライアント側でHTTPSを強制する HSTS ヘッダーの有効化が推奨されています。また、Webフロー・Webサービスでは信頼できるSSL証明書でHTTPS（SSL/TLS）を使います。（出典）

第5章 Reactive Webセキュリティと安全な開発（Q37–Q43）

Q37. リアクティブWebアプリの **クライアント変数** について、ベストプラクティスとして正しいものはどれか。

- A. サーバー側に保存されるため、機密データの保存に適している
- B. 暗号化されて保存されるため、アクセス制御のフラグに使ってよい
- C. 1つのアプリ内でのみ有効で、他のアプリとは共有されない
- D. ブラウザのローカルストレージに保存されアプリ間で共有できるため、機密データを保存したり、アプリのフロー制御に使ったりしない

正解: D — クライアント変数はブラウザのローカルストレージ（HTML Web Storage）に保存され、アプリ間で共有可能です。改ざんされうるため、機密データの保存やフロー制御には使いません。（出典）

Q38. リアクティブWebアプリで、クライアント側から使われる Aggregate やサーバーアクションについて正しい記述はどれか。

- A. クライアントから直接データベースに接続して実行される
- B. 画面のロール設定に関係なく、常に認証が必要になる
- C. それぞれに対応するREST APIメソッドが作成され、画面に Anonymous ロールが設定されているとそのAPIも公開される
- D. Anonymous ロールの画面では Aggregate を使用できない

正解: C — クライアント側で使う Aggregate・サーバーアクションごとにREST APIメソッドが作られます。画面が Anonymous なら、そのAPIも公開されるため、入力パラメータを操作されても別レコードを取得できないようにする必要があります。（出典）

Q39. リアクティブWebアプリで「ログイン中のユーザー自身のデータ」を取得したい。最も安全な実装はどれか。

- A. Aggregate のフィルタ内で `GetUserId()` を使い、サーバー側でユーザーを特定する
- B. クライアント変数に保存した UserId を Aggregate の入力パラメータで渡す
- C. 画面の入力パラメータで UserId を受け取る
- D. 全ユーザーのデータを取得し、クライアント側でフィルタする

正解: A — Aggregate はサーバーで実行されるため、内部で `GetUserId()` を使えば攻撃者がクエリを改変して他ユーザーのデータを取得できません。（出典）

Q40. 1つの画面にロールごとに異なる機能が混在している。リアクティブWebのベストプラクティスとして推奨される対応はどれか。

- A. ロールに応じてクライアント側でボタンを非表示にする
- B. 画面に Anonymous ロールを追加する
- C. クライアント変数でロールを判定する
- D. ロールごとに別々の画面を作り、それぞれに必要な機能だけを持たせる

正解: D — 1画面にロールを混在させると、クライアント側で機能を隠しても改ざんでアクセスされうるため、ロールごとに画面を分けることが最も簡単で安全とされています。（出典）

Q41. リアクティブWebセキュリティの「Tips」として挙げられているものはどれか。

- A. テスト用画面は本番環境でも残しておき、障害調査に使う
- B. TrueChange の警告は性能に関するものなので無視してよい
- C. テスト用画面を開発環境以外にデプロイしない。サードパーティのプラグインも定期的に確認・更新する
- D. サードパーティのプラグインは一度導入したら更新しない方が安全

正解: C — テスト用画面は多くの場合 Public で、データベースを改ざんされる恐れがあるため開発環境以外にデプロイしません。サードパーティのプラグインの既知の脆弱性にも注意し、定期的に更新します。TrueChange の警告も重視するよう推奨されています。（出典）

Q42. OutSystems がデフォルトで提供する「セッション固定攻撃からの保護」の仕組みとして正しいものはどれか。

- A. セッションIDをURLに含めて毎回検証する
- B. セッションを使わずにすべてクライアント変数で状態を管理する
- C. ログイン画面を Anonymous にしない
- D. ログインごとにセッションIDを透過的に変更し、リクエストごとに検証する

正解: D — ログインのたびにセッションIDを変更し、リクエストごとに検証することでセッション固定攻撃を防ぎます。（出典）

Q43. 「How the OutSystems Platform Helps You Develop Secure Applications」で示される開発ベストプラクティスが、主にリスク軽減の対象としている層はどれか。

- A. ネットワーク層
- B. システムインフラ層
- C. アプリケーション層
- D. 物理セキュリティ層

正解: C — エンタープライズの技術層（アプリケーション・ネットワーク・システムインフラ）のうち、このガイドはアプリケーション層のリスク軽減を目的とし、OWASP Top 10 をもとに6つの保護テーマ（アクセス制御、認証、インジェクション/XSS、CSRF、暗号化、リダイレクト）を示しています。（出典）

第6章 サーバー強化・エンタープライズ・HIPAA・ライセンス（Q44–Q50）

Q44. Platform Server ハードニングの「初期ユーザー設定」で推奨されている対応はどれか。

- A. 管理者アカウントは無効化し、ITユーザーのみで運用する
- B. Users アプリの管理者パスワードは本番環境だけ変更すればよい
- C. 既定パスワードは OutSystems が自動で変更するため対応不要
- D. 各環境の Users アプリの Administrator と、LifeTime の管理者ユーザーのパスワードを初回利用時に変更し、ローテーションポリシーを適用する

正解: D — 環境ごとの Users テナントには既定パスワードの Administrator がある場合があるため、各環境で変更します。LifeTime の管理者もパスワード変更とローテーションが推奨されています。（出典）

Q45. バックオフィス用アプリを限られたIP範囲からのみ利用させたい。Platform Server ハードニングのページで推奨されている仕組みはどれか。

- A. CSP の frame-ancestors を設定する
- B. 画面のロールを Registered にする
- C. Users アプリの Blocked Addresses に許可IPを登録する
- D. 内部ネットワーク（Internal Network）を構成し、Web UIフロー・公開SOAP・公開REST APIを内部ネットワーク内のみで利用可能にする

正解: D — 内部ネットワーク設定により、Web UIフロー、公開SOAPサービス、公開REST APIを内部ネットワーク限定にでき、バックオフィス系アプリでの利用が推奨されています。（出典）

Q46. Factory Configuration で設定できるセキュリティヘッダーのうち、ページを `<frame>` や `<iframe>` 内に表示してよいかを指定し、クリックジャッキング対策に使えるものはどれか。

- A. X-Frame-Options
- B. X-XSS-Protection
- C. Strict-Transport-Security
- D. Content-Type

正解: A — X-Frame-Options はフレーム内での表示可否を示し、クリックジャッキング回避に使えます。X-XSS-Protection は反射型XSSを検知したときに読み込みを止めるもので、CSP 非対応の古いブラウザ向けの保護です。（出典）

Q47. OutSystems 評価ガイド「アプリケーションのセキュリティ」の記述として正しいものはどれか。

- A. OutSystems は中間の3GLコード（JavaScript、.NET など）を生成するため、それをサードパーティの SAST ツールに渡して追加のセキュリティ分析ができる
- B. 生成コードは暗号化されているため、外部のSASTツールでは解析できない
- C. 使用していないアプリや所有者のいないアプリは自動的に削除される
- D. デプロイアクティビティは監査対象外である

正解: A — 生成された中間3GLコードをサードパーティのSASTツールに渡せます。使用していないアプリや孤立したアプリには自動でフラグが立ち（削除ではない）、デプロイアクティビティも監査されます。（出典）

Q48. OutSystems 評価ガイド「エンタープライズセキュリティポスチャ」における OutSystems Sentry の説明として正しいものはどれか。

- A. すべてのサブスクリプションに標準で含まれる無償機能である
- B. モバイルアプリ専用の難読化ツールである
- C. オンプレミス環境専用のファイアウォール製品である
- D. 機密データや規制業界向けに追加のセキュリティ・リスク管理・監視を提供するアドオンで、SOC 2 Type II、ISO 27001、HIPAA、PCI DSS などの認証を取得している

正解: D — Sentry はアドオンで、SOC 2 Type II、ISO 27001、ISO 22301、HIPAA、PCI DSS、TISAX の認証取得が挙げられています。なお、OutSystems Support サービスは ISO 27001 認証を取得していると記載されています。（出典）

Q49. HIPAA の技術的予防措置「自動ログオフの実装 (A) 164.312(a)(2)(iii)」に対して、OutSystems が提供する機能として挙げられているものはどれか。

- A. Users アプリのパスワード有効期限
- B. ブルートフォース保護の第2バックオフ
- C. CSP の default-src ディレクティブ
- D. アイドル状態で継続できる期間を指定するセッションタイムアウトにより、Platform Server がセッションを自動終了する仕組み

正解: D — セッションタイムアウトのパラメータで、操作がないまま継続できる期間を指定し、超えると Platform Server がセッションを終了します。なお、チェックリストの (R) は必須、(A) は対処可能（addressable）を示します。（出典）

Q50. OutSystems のライセンスにおけるエンドユーザーのカウントについて正しいものはどれか。

- A. ログインせず、氏名やメールアドレスなどの個人を特定できる情報も提供しない匿名ユーザーはカウントされない
- B. OutSystems 11 では、内部ユーザードメインを定義する前はすべてのユーザーが外部ユーザーとして扱われる
- C. アプリを開発するだけで使用しない開発者もエンドユーザーとしてカウントされる
- D. 無効化したユーザーも引き続きエンドユーザー数にカウントされる

正解: A — 匿名エンドユーザーはカウント対象外です。O11 ではドメイン定義前は全員が内部扱い、メールアドレスのないユーザーも内部扱いです。開発のみの人はエンドユーザーではなく、無効化したユーザーはカウントから外れます。（出典）

解答一覧

50問の正解は A 12問・B 17問・C 11問・D 10問です。B がやや多いため、選択肢の位置で推測しないよう注意してください。

章	問題	正解
第1章 認証・ブルートフォース	Q1–Q9	1-B　2-C　3-A　4-A　5-B　6-C　7-B　8-A　9-B
第2章 ロールとアクセス制御	Q10–Q17	10-B　11-A　12-C　13-B　14-B　15-C　16-B　17-B
第3章 インジェクション・XSS・CSP	Q18–Q28	18-B　19-A　20-B　21-B　22-B　23-B　24-A　25-A　26-B　27-B　28-B
第4章 CSRF・リダイレクト・暗号化	Q29–Q36	29-C　30-D　31-C　32-D　33-C　34-D　35-A　36-C
第5章 Reactive Web・安全な開発	Q37–Q43	37-D　38-C　39-A　40-D　41-C　42-D　43-C
第6章 強化・エンタープライズ・HIPAA・ライセンス	Q44–Q50	44-D　45-D　46-A　47-A　48-D　49-D　50-A

出典についての補足: 指定URLのうち英語版の「How the OutSystems Platform Helps You Develop Secure Applications」はアクセスが拒否されたため、同じ記事の日本語サイト版（本文は英語）を読んで Q43 を作成しました。それ以外の21ページは指定どおりのURLを読んでいます。